DAST con OWASP ZAP

Resultados — Ronda 3

Equipo SOS Clinic

22 de octubre de 2026

1 Resumen

Métrica	Valor
URLs analizadas	17
Reglas pasadas	**62 PASS**
Fallos	**0 FAIL**
Advertencias	**6 WARN**
Información	0 INFO

Cuadro 1: Resumen del baseline de ZAP.

No hay fallos. Las seis advertencias se evaluaron manualmente; ninguna representa una vulnerabilidad explotable en el contexto actual.

2 Advertencias y evaluación

Regla	Ocurrencias	Evaluación
Cross-Domain JavaScript Source Inclusion [10017]	3	Bajo. Recursos de YouTube esperados en el landing; no los controla el usuario.
Non-Storable Content [10049]	9	Informativo. `Cache-Control: no-store` es intencional en páginas con sesión.
CSP: Wildcard Directive [10055]	12	Bajo/medio. Fuentes de esquema y `unsafe-inline`; se relaciona con F-03.
Modern Web Application [10109]	3	Informativo. Detecta la SPA; no es vulnerabilidad.
Sub Resource Integrity Missing [90003]	3	Bajo. Recursos locales del mismo origen; el script de YouTube es externo.
Cross-Origin-Embedder-Policy Missing [90004]	9	Bajo. COEP es opcional; COOP y CORP sí están presentes.

Cuadro 2: Advertencias de ZAP y su clasificación.

3 Controles que pasaron

ZAP no encontró problemas en:

- Cabeceras anti-clickjacking y `X-Content-Type-Options`.
- Ausencia de CSP (la CSP existe) y divulgación de errores.

- Comentarios sospechosos, información sensible en URL o referrer.
- Cookies (la aplicación usa `sessionStorage`, no cookies).
- Enlaces a dominios maliciosos, *mixed content* y *source code disclosure*.
- Tecnologías con versiones vulnerables.

Las cabeceras observadas en el frontend incluyen `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: no-referrer`, `Permissions-Policy`, `COOP`, `CORP` y una CSP con `unsafe-inline`.

4 Mejoras

1. Endurecer la CSP: retirar `unsafe-inline` y restringir `img-src`/`media-src` a orígenes concretos.
2. Añadir *Subresource Integrity* si se incorporan scripts de terceros que lo permitan.
3. Evaluar `Cross-Origin-Embedder-Policy` si se aíslan recursos cross-origin en el futuro.
4. Mantener el análisis baseline en la CI para detectar regresiones de cabeceras.

5 Evidencias

- `seguridad/resultados/zap-baseline-r3.html`
- `seguridad/resultados/zap-baseline-r3.json`
- `seguridad/resultados/zap-baseline-r3.md`

6 Conclusión

El frontend no presenta fallos pasivos y las advertencias son de bajo impacto o decisiones intencionales. El único punto a mejorar con impacto real es la CSP con `unsafe-inline`, ya identificado en el pentest como F-03.